

Gate-to-PC Exclusion Policy

Letting the right people work when the door can't vouch for them — without switching the control off.

1. What this is

Gate-to-PC is the SmartEPT signature control: when a company switches it on, an employee's desktop agent **will not start a work session until a real door / biometric IN punch reaches SmartEPT**. No punch, no working desktop. It is what makes buddy-punching and proxy attendance structurally impossible rather than merely discouraged.

That strength is also its weakness. A control that admits no exceptions breaks the moment reality does — and reality does, regularly. The **Exclusion Policy** is the supported way to say *"this branch / this team / this person / this machine may sign in without a punch, for these dates, for this reason, on my authority."*

It is a **standing policy**, configured once and audited. It does not replace the existing one-off emergency override (`POST /agent-override/gate`), which stays for *"fix it in the next thirty seconds."*

2. Why it exists — the four real situations

These are the situations that drove the requirement. Any of them, without an exclusion, ends with a productive employee sitting in front of a locked PC.

2.1 The reader is down

The door controller has failed, is powered off, or is out for RMA. **Nobody** at that site can punch in. Every employee at that branch arrives to a walled agent. Left alone, an admin ends up issuing dozens of individual emergency overrides every morning until the engineer arrives.

Use: one exclusion on the **Branch**, dated from today to the day the engineer is booked.

2.2 One person's punch is not accepted

The reader is healthy, but *this* employee's finger will not read — a cut, dry skin, a worn enrolment — or their card is damaged and a replacement is on order. Everyone else walks in normally; this one person is stuck at the door every single morning.

Use: one exclusion on the **Employee**, dated until the re-enrolment appointment.

2.3 The punch happens, but never reaches SmartEPT — network or link outage

This is the most common and the most disruptive case, and the least obvious.

The employee *did* punch in. The reader accepted it, beeped, and stored it. But the site's network or internet link is down, or the middleware service has stopped, so the punch is sitting on the device and has not reached the SmartEPT server. From the product's point of view the employee has simply not arrived — so the agent shows the gate wall and refuses to start their work session.

Nothing is broken at the door. Nothing is broken with the employee. The punch exists; the server just cannot see it. Meanwhile the employee is at their desk, unable to work, through no fault of anyone's — and the disruption lasts as long as the link is down, which can be hours.

Use: an exclusion on the **Branch** (or the affected Department) covering the outage window. When connectivity returns, the queued punches sync and normal attendance resumes; the exclusion lapses on its own date and the gate re-arms with nobody having to remember.

Note: those late-arriving punches are still ingested and still merge into the attendance record when the link recovers — the exclusion only affects whether the **agent is allowed to start**, not what is eventually recorded. The day's attendance stays truthful.

2.4 People who never pass a reader at all

Night-shift staff on a door with no reader, field engineers who go straight to site, work-from-home developers, visiting contractors on a loan laptop. For these the exclusion is intentionally permanent — leave the dates blank.

3. How it works

3.1 Five levels, most specific wins

Every level of the organisation can carry a gate setting. The resolution walks from the most specific to the least, and **stops at the first level that says anything**:

Machine → Employee → Team → Department → Branch

Each level is one of three values:

Setting	Meaning
Inherit (blank)	Say nothing; the decision passes to the level above. This is the default everywhere, so an existing installation is completely unaffected.
Excluded	This person / group may start a work session on credentials alone. No door punch needed.
Required	This person / group must punch in — even if a level above them is Excluded.

Required is what makes the policy usable at scale. Without it, an exclusion at branch level would be all-or-nothing. With it:

Exclude the whole **Ahmedabad branch** while the reader is being repaired, but mark the **Security team Required** — they carry the spare cards and are expected to use the manual register, so they stay behind the gate.

Above all five sits the company switch. If Gate-to-PC is **off** for the company, or the organisation's attendance source is "**Without biometric device**", then nobody is gated at all and exclusions have nothing to do. The Gate Exclusions screen says so plainly at the top rather than implying people are being let through.

3.2 Dates: the part that matters most

Every exclusion can carry **Valid from** and **Valid until**. Both days are included.

- **Both blank** → permanent, until an administrator removes it.
- **Dates set** → the setting applies only inside that window. Outside it, the level reads as if it were blank and the decision passes upward exactly as it would have before.

This is deliberate and it is the single most important design decision in the feature. A temporary exclusion that must be manually removed *will not be removed*. Somebody grants it on a Tuesday because the reader is broken, the engineer comes on Thursday, and the exclusion is still there a year later — at which point the control has quietly stopped existing and nobody knows. A dated exclusion **re-arms the gate by itself** the day after it ends. There is no scheduled job to fail, no reminder to ignore, and no cleanup task.

Dates are evaluated in **the customer's own timezone** — the branch's if it sets one, otherwise the company's. An exclusion dated "until the 22nd" dies at midnight local, not at midnight UTC.

3.3 Reason and accountability

Every exclusion records:

- **Reason** — free text, shown in the list. Write the actual cause: *"site link down — punches are on the device but not reaching SmartEPT."*
- **Granted by** — stamped by the server from the signed-in administrator. It cannot be set or spoofed by a client, and anyone who later edits the exclusion — including simply extending its end date — becomes the person recorded against it.
- **Audit entry** — every change is written to the audit log alongside every other administrative action.

4. Using it in the console

4.1 Where it lives

Manage → Gate Exclusions, directly below Biometric in the sidebar.

The screen hides itself when the organisation's attendance source is *Without biometric device*, because with no reader there is no gate to be excluded from.

4.2 The screen

The top card states whether Gate-to-PC is currently on, so an exclusion list is never read out of context. Below it, every standing exclusion in the company appears in one table:

Column	What it tells you
Level	Branch, Department, Team, Employee or Machine
Applies to	The specific site / group / person / PC
Setting	Excluded or Required
From / Until	The validity window; a dash means no bound
Status	Active (in force now), Scheduled (starts later), Expired (lapsed, no longer doing anything)
Reason	Why it was granted
Granted by	The administrator accountable for it

Scheduled and *Expired* exist because "why isn't my exclusion working?" is almost always one of those two, and previously there was no way to see it.

4.3 Adding one

+ **Add exclusion** → choose the level, choose who it applies to, choose Excluded or Required, optionally set the dates, write the reason, Save. **Remove** puts that group straight back behind the door punch.

The same controls also appear where you would naturally look for them: on the employee record (Employees → Edit) and on branch / department / team records (Organisation).

4.4 How fast it takes effect

Within about **15 seconds**. The agent re-polls its gate status continuously, so a person sitting at a walled PC is released without restarting anything, and revoking an exclusion re-arms their gate just as quickly. No reinstall, no re-bind, no logout.

5. Worked examples

The reader died and the engineer comes Friday. Gate Exclusions → Add → Level *Branch* → *Ahmedabad* → *Excluded* → from today, until Friday → reason "*Door controller RMA — engineer booked Friday.*" Everyone at that site works normally for three days. On Saturday the gate is back on by itself.

The site link is down and punches aren't arriving. Same shape, but at *Branch* or *Department*, dated to cover the outage — reason "*ISP outage, punches held on the device.*" When the link returns the queued punches sync into attendance as normal; the exclusion lapses on its date.

Her fingerprint stopped reading on Monday. Level *Employee* → the person → *Excluded* → from Monday, until the re-enrolment appointment → reason "*Fingerprint not reading — re-enrolment booked 25 Aug.*" Only she is affected.

Night shift, permanently, on a door with no reader. Level *Team* → Night Operations → *Excluded* → **no dates**. Reason recorded, reviewed whenever the exclusion list is audited.

Excluded site, but one team must still punch. Branch *Excluded*; Security team *Required*. Most specific wins, so the security team stays gated while the rest of the site is free.

6. For administrators: keeping it honest

The Exclusion Policy widens a security control on purpose. A few habits keep it from widening further than intended:

1. **Date everything you can.** Only 2.4-type cases (people who genuinely never pass a reader) deserve a blank end date. If there is any date at which the cause will be resolved, put it in.
2. **Write a real reason.** "Temp" tells the next reviewer nothing. The cause and the fix do.
3. **Read the list occasionally.** One screen, one glance. *Expired* rows are harmless but are worth clearing; a long list of undated *Active* rows means the gate is mostly off.
4. **Prefer the narrowest level that solves the problem.** A branch exclusion for one person's broken finger frees the entire site.
5. **Use *Required* rather than removing a broad exclusion** when only a sub-group should stay gated.

7. Technical reference

7.1 Data

Five tables gain the same nullable columns — `employees`, `employee_devices`, `teams`, `departments`, `branches` :

Column	Type	Meaning
<code>gate_mode</code>	string(16), null	<code>EXCLUDED</code> , <code>REQUIRED</code> , or NULL = inherit
<code>gate_mode_from</code>	date, null	First day it applies; NULL = immediately
<code>gate_mode_until</code>	date, null	Last day it applies, inclusive; NULL = no expiry
<code>gate_mode_reason</code>	string(255), null	Why it was granted
<code>gate_mode_by_user_id</code>	bigint, null	Which administrator granted it (server-stamped)

Migrations `2026_08_18_000100_add_gate_mode_to_org_chain` and `2026_08_18_000200_add_gate_exclusion_window_to_org_chain`. Both are additive, guarded by `hasColumn`, and re-runnable. Nothing is set anywhere by default, so **applying them changes no existing behaviour**.

`companies` deliberately gains nothing: the company level already has `biometric_gate` (`auto` / `on` / `off`) and `gate_enabled`, and a third company-level switch saying the same thing is how "which flag wins?" bugs start.

7.2 Resolution

`App\Services\GateService::exclusionFor(Employee, ?EmployeeDevice)` walks DEVICE → EMPLOYEE → TEAM → DEPARTMENT → BRANCH and returns at the first level whose `gate_mode` is set **and** whose window is live today in the tenant's timezone. Everything that enforces the gate goes through it — `AttendanceController` (LOGIN/UNLOCK), `ResolvesAgentContext::assertGateOpen` (activity, idle and screenshot ingestion), `AgentStatusController`, the device heartbeat, and the punch-replay path.

7.3 API

Method	Route	Purpose
GET	<code>/api/gate-exclusions</code>	Read-only roll-up across all five levels, with <code>ACTIVE</code> / <code>SCHEDULED</code> / <code>EXPIRED</code> status and company gate state
GET	<code>/api/employees/{id}/gate-trace</code>	Why this person is gated (or not): company switch, resolved exclusion level, live gate state
PUT	<code>/api/employees/{id}</code>	<code>gate_mode</code> , <code>gate_mode_from</code> , <code>gate_mode_until</code> , <code>gate_mode_reason</code>
POST / PUT	<code>/api/org/{type}/{id}</code> — type = <code>branches</code> , <code>departments</code> or <code>teams</code>	Same four fields
PUT	<code>/api/devices/{id}/gate-mode</code>	Same four fields, for one machine

All are restricted to Super Admin / Company Admin / Branch Admin / HR Admin. No self-service route reaches these fields, and `gate_mode_by_user_id` is absent from every validation whitelist — a client cannot claim someone else authorised an exclusion.

`GET /api/agent/gate-status` now also returns `excluded`, `excluded_level`, `excluded_until` and `exclusion_reason` alongside the existing `gate_required` / `open` / `reason`, so the agent can say *why* it is not asking for a punch. Older agents that ignore the new keys are unaffected.

7.4 Verification

`tests/Feature/GateExclusionPolicyTest.php` — 27 feature tests covering each precedence level, the Required claw-back, window start / expiry / lapse-to-parent, tenant-timezone boundaries, the roll-up's status classification, attribution and re-attribution, and the specific failure modes found in review (below). Full suite: 205 tests.

7.5 Review history

The change was put through two rounds of adversarial review, biased toward finding ways the control could fail **open**. Twelve defects were found and fixed before release, including: a soft-deleted branch that kept granting its exclusion; a laptop re-registered by a second client company carrying the first company's exclusion across tenants; date windows evaluated in UTC rather than the customer's timezone (which left an expired exclusion lifting the gate through the first five and a half hours of every night shift in India); screenshot ingestion resolving the gate at a different level from every other route; an unbound machine still walling its former user; a partial edit silently turning a dated exclusion into a permanent one while keeping the original grantor's name on it; and a cross-site-scripting hole in the new screen's table where a crafted branch name or PC name could run script in an administrator's session.

| 8. Deployment

1. `php artisan migrate` — two additive migrations.
 2. `php artisan optimize:clear` (or restart the web server).
 3. Nothing to change on the agent. Existing installed agents pick up the new behaviour on their next gate poll, within about 15 seconds.
 4. Nothing is excluded until an administrator creates an exclusion.
-

Ametecs India — internal. SmartEPT · Employee Productivity Tracking.